Engineering Resilience: Applying CIE to Global Maritime Logistics Supply Chains

Foreword

by **Dr Sue D. Bug**

Executive Director of the Lancaster Cyber Forum

This white paper analyses the systemic vulnerabilities exposed by the 2017 “NotPetya" cyberattack, focusing on its devastating collateral impact on A.P. Møller-Maersk, a Danish maritime logistics company that operates world-wide. While the main target was the Ukrainian infrastructure, a critical failure in legacy IT-centric models led to the propagation of malware into A.P.Møller-Maersk global network. This shows how a single compromise in the supply chain can paralyse global trade causing millions of dollars of losses due to the ripple effect of the attack. This case also illuminates the growing use of cyberattacks in geopolitical conflicts and how the ramification of those causes a global economy disruption.

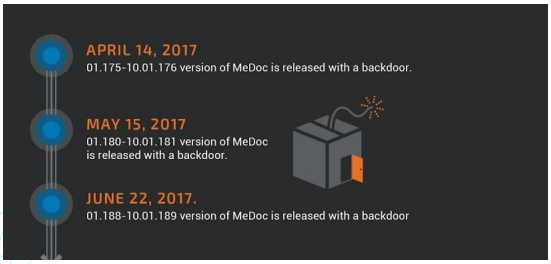
Thus, this report argues that standard network defence mechanisms are insufficient for Operational Technology (OT) environments like shipping. Therefore, it introduces the idea of adopting Cyber-Informed Engineering (CIE) principles. This shifts the focus on resilience, prioritizing the ability to withstand a digital failure from the earliest design stages. The following sections detail a set of lessons points and engineering-focused mitigation strategies to prevent similar catastrophic outcomes.

Background

The malware discussed in this report is widely known as NotPetya, though it is also referred to as Petya, Petrwrap, and GoldenEye.

The Russian cyber operations against Ukraine began in 2015, after the onset of the conflict between these two countries in 2014. The series of cyber-attacks culminated in the deployment of the **NotPetya** [6] malware in 2017 that spread all over the world to associated businesses of the infected Ukrainian companies. GRU (Russian Main Intelligence) attackers were sending a message with this action: there would be a blowback for any foreign company working in Ukraine or anyone doing business there because they were moving away from the soviet-master [12].

According to CISA (Cybersecurity and Infrastructure Security Agency), the NotPetya ransomware spread rapidly across systems [3] using EternalBlue that exploits a SMB1 protocol vulnerability on Windows systems (CVE-2017-0144) [11]. This vulnerability was originally discovered and weaponized by the NSA (National Security Agency), but never disclosed due to its usefulness for offensive security operations. However it became a serious matter only when a group of hackers called Shadow Brokers leaked the discovered vulnerability online, after stealing it and failing to auction it in 2017. While Microsoft had been informed of the zero-day vulnerability only after this issue, the malicious software was already seen in action since 2016. The attack first started compromising a Ukrainian tax software (SaaS) supply chain, injecting a malware with a backdoor through the automatic update system. Logs recovered during the forensic analysis showed that the M.E. Doc's (the subject tax software) centralized update systems had been compromised since April, while the attack took place the day before Ukrainian Constitution Day, the 27th of June 2017. [2, 6] The analysis revealed that despite the ransom demand ($300 in BitCoin), the malware was a wiper designed solely for destruction, not financial gain. Cisco Talos Intelligence tracked the initial compromise of M.E.Doc [1] (see fig. 1) and documented the global propagation [2]. Technical analysis of the malware behaviour is available in the LogRhythm report [10].



(a) M.E.Doc Supply Chain Compromise Roadmap [1]



(b) M.E.Doc Supply Chain Compromise Roadmap [1]

Fig. 1. M.E.Doc exploit roadmap

The malware's lateral propagation relied on two key mechanisms: the **EternalBlue** exploit for unpatched systems, and **Mimikatz** (a credential-harvesting tool), to move across fully patched networks. This allowed the malware to jump from the initial M.E.Doc infection to critical domain controllers, devastating networks globally, including that of A.P. Møller-Maersk.

Crucially, Maersk did not lose direct control of ship propulsion systems; rather, they lost the centralized IT coordination necessary for logistics. NotPetya hit the land-based IT network (HQ, Ports) and the malware spread to the port terminals. While the physical port infrastructure (cranes, power) remained functional, the dependency on Windows-based servers for cargo manifests rendered them inoperable. When the Windows servers encrypted themselves the cranes still had power (OT worked), but nobody knew which container was which (IT failed). The port froze because they couldn't load a ship without knowing the content of each container (e.g. they didn't know if a box contained iPhones or toxic waste).

Steinberg et al. (2021) stated that Maersk was a "global behemoth, it had over 75,000 employees in 130 countries overseeing logistics, ports, and shipping lines. Like most companies, Maersk did not see itself as the potential object of a targeted cyberattack, while its risk managers did not understand just how quickly and widely the computer systems on which the companies' most basic operations relied could be compromised, let alone recovered, in case of disruption" [12].

In summary, it can be deducted from this description that there was a substantial lack of security in terms of prevention and a lot of critical aspects have emerged after this episode. The next sections address the principles of security beneath a supply chain in Global Maritime Logistics and how Cyber-Informed Engineering/Consequence-driven CIE (CIE/CCE) can help build a solid security posture.

Global Maritime Logistics: Introducing Supply Chain Security

Historically, the maritime environment used to be analog and safe, made of physical air-gaps and relying on the "security by obscurity" paradigm. A vessel disconnected from digital infrastructures is inherently isolated from remote cyber threats. However, due to the pursuit of efficiency, a rapid convergence of Information Technology (IT) and Operational Technology (OT) has transformed the maritime logistics sector. Modern ships are effectively floating data centres, that rely on continuous VSAT satellite uplinks for ECDIS (Electronic Chart Display and Information System) updates, remote engine diagnostics and real-time cargo tracking.

This new hyper-connectivity created a problem: everything was on one network.
As demonstrated by the Maersk incident, relying on a "flat network" meant facilitating rapid lateral propagation of the malware from a shore-based compromised accounting software to port terminals and cargo vessels worldwide. The attack vector was not a direct breach of Maersk's patched network, but a Software Supply Chain attack via a trusted vendor (M.E.Doc) that had the privilege to install automatically updates on subscribed machines and execute remotely arbitrary code. This is crucial to underscore a critical vulnerability in the sector: logistics' systems rely on a vast web of third-party software, each representing a potential entry point to get around traditional perimeter defences. These dependencies often are underestimated rather than being considered as possible attack paths. Consequently, engineering secure and reliable pipelines is a must in high risk sectors. In the maritime logistics sector, designing systems in such ways wasn't a common practice because it wasn't considered as much important, even though it is the backbone on which the global economy relies for commercial

trades. For instance, the Maersk's operational stop resulted in more than $300 million in losses in a matter of weeks [12].

The NotPetya attack exposed the fragility of this digitized ecosystem [2, 12]. The halting of Maersk's ports was not due to an OT failure, but the unavailability of the IT systems (central database) required to operate the cranes. This common cause failure, where the IT becomes unreachable and therefore physical operations are halted, reveals the need for a **paradigm shift**. Standard risk management, intended for "preventing the hack" isn't sufficient anymore. The sector must rely on solid security principles, that prioritize the resilience of essential physical operations, even during a network impairment. **Cyber-Informed Engineering** is the most suitable methodology to adopt in order to design robust systems that can withstand serious adversities.

How Cyber-Informed Engineering Contributes to Resilience

The maritime sector must tackle the challenges posed by the convergence of IT/OT and it cannot be done only by patching its way out of the problem. Instead, there is the necessity to shift to something fundamentally different: Cyber-Informed Engineering (CIE). Developed by the U.S. Department of Energy (DOE), CIE is a strategic methodology that embeds cybersecurity considerations into the engineering design lifecycle from earliest design phases (inception) [13].

At the operational level, this is implemented through **Consequence-driven Cyber-informed Engineering (CCE)**: a rigorous four-phase methodology developed by Idaho National Laboratory (INL) [7]. Unlike standard security assessments that focus on compliance, CCE starts by asking: *"What is the catastrophic failure that must be prevented at all costs?"*. CCE, specifically, is an iterative methodology: organizations revisit and improve their assumptions and analysis based on the evolution of operational dependencies and adversary capabilities. The following subsection shows a hypothetical application of the CCE framework to the Maersk incident and provides a structured analysis to understand how its adoption could have prevented the catastrophic operational paralysis.

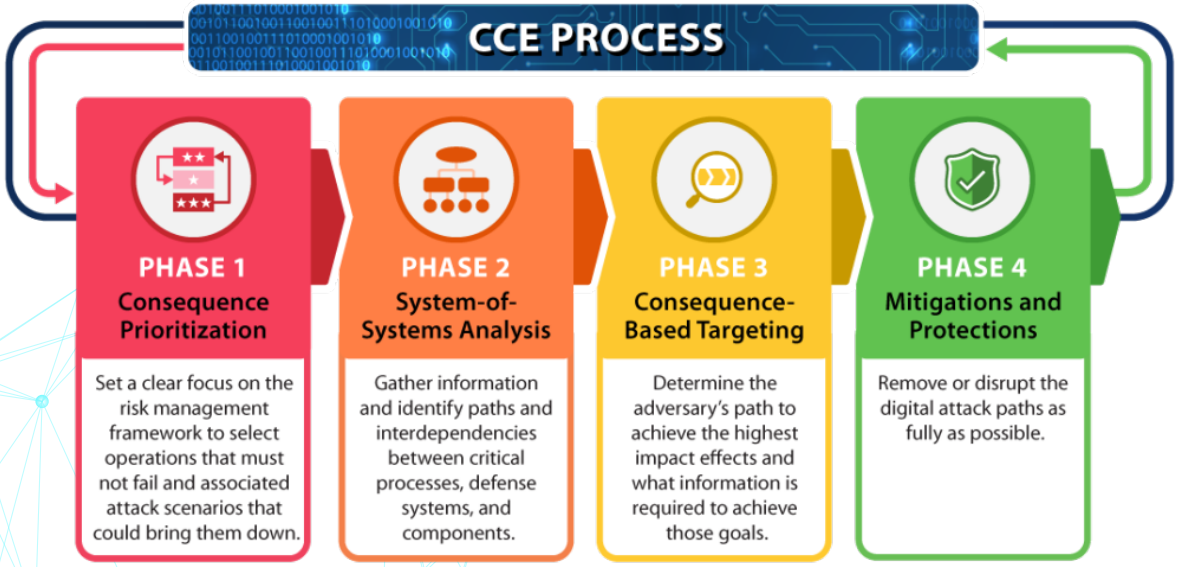


Fig. 2. CCE 4-phase diagram [7]

Applying CCE to Maritime Logistics Resilience

The NotPetya incident served as a stark wake-up call: organizations must adopt structured methodologies that aid in identifying and mitigating specific dependencies that could trigger a systemic collapse. Security engineers must embrace purple teaming (defence strategies developed from an attackers point of view) applied to critical operations, in a way that assets are subsequently protected in a constantly evolving threat and technological landscape.

The CCE framework addresses this issue with rigour, here is how the four-phase process would prevent a recurrence of the Maersk operational paralysis:

- **Phase 1: Consequence Prioritization (Identifying the HCE)**
  The first step is asking: *what's the worst thing that could happen?* For Maersk, the worst case was not the loss of data, but the inability to physically move cargo. That is the High Consequence Event (HCE), where CCE says to protect that first and everything else is secondary. By prioritizing physical operations over standard data integrity, CCE shifts the focus to protecting operations that actually keep the port running [8].
- **Phase 2: System-of-Systems Analysis (Mapping Dependencies)**
  During this phase the digital dependencies of critical physical functions are mapped. At that time an analysis of Maersk's architecture would have revealed a critical "Common Cause Failure": the port cranes (OT) had a hard dependency on real-time connectivity to the central IT servers. This unsegmented dependency meant that an IT failure would have triggered an OT blackout consequently [1].
- **Phase 3: Consequence-Based Targeting (The Attacker's View)**
  CCE operates on the assumption that a sophisticated adversary is already behind the protected perimeter. In the NotPetya case, the attackers did not target the cranes directly but exploited the *Software Supply Chain* (M.E.Doc) to cripple the logic layer [12]. This phase highlights that legacy perimeter security (firewalls) cannot stop an authorized but compromised vendor update. Therefore, traditional IT risk management is insufficient to protect OT assets.
- **Phase 4: Mitigation and Protections (Engineered Decoupling)**
  The final phase implements engineering controls to "designing out" the risk. The primary solution is **Engineered Decoupling**: ensuring that critical OT systems can function independently of the IT network.
  - *Local Autonomy:* Designing cranes with local read-only caches of manifest data, allowing operations to continue even when the central network is severed.
  - *Analog Fallbacks:* Implementing non-digital verification processes (e.g., physical manifests) as a mandatory fail-over, preventing total operational paralysis.

Ultimately, this prepares the organizations to be ready for systemic failure. It gives a solution to "patch" the Maersk's architectural vulnerabilities exposed by NotPetya. The key lies in isolating critical operations by applying a fail-safe paradigm that guarantees a viable recovery path, regardless of the digital state of the network.

Future Perspectives

The maritime sector is evolving towards a greater digitized and autonomous environment, aiming for efficiency optimization and cost reduction. At the same time the threat landscape is shifting from opportunistic criminal ransomware to targeted geopolitical sabotage, introducing the concept of “Hybrid Warfare". This section analyses emerging trends that will either mitigate or exacerbate the vulnerabilities exposed by the NotPetya incident.

New Regulatory Enforcers: IACS E26/E27 and NIS2

The good news: Now the "Secure by Design" is a standard also in the maritime sector. Which means that the International Association of Classification Societies (IACS) has now introduced Unified Requirements **UR E26** and **UR E27** [9]. Any new cargo ships contracted after July 2024 is required to comply to them.

- **UR E26** imposes that cyber resilience has to be integrated into the vessel’s design phase, effectively enforcing the CIE principles of network segmentation and redundancy.
- **NIS2 Directive**: In the EU, the NIS2 Directive now classifies maritime transport as **Essential Infrastructure**, imposing strict requirements for supply chain security [5]. This forces security engineers to vet vendors like M.E.Doc rigorously, shifting the sector towards a "Zero Trust" supply chain model.

These regulations validate the argument that resilience is no longer an option but a license to operate.

The new era of maritime logistics: Autonomy and AI

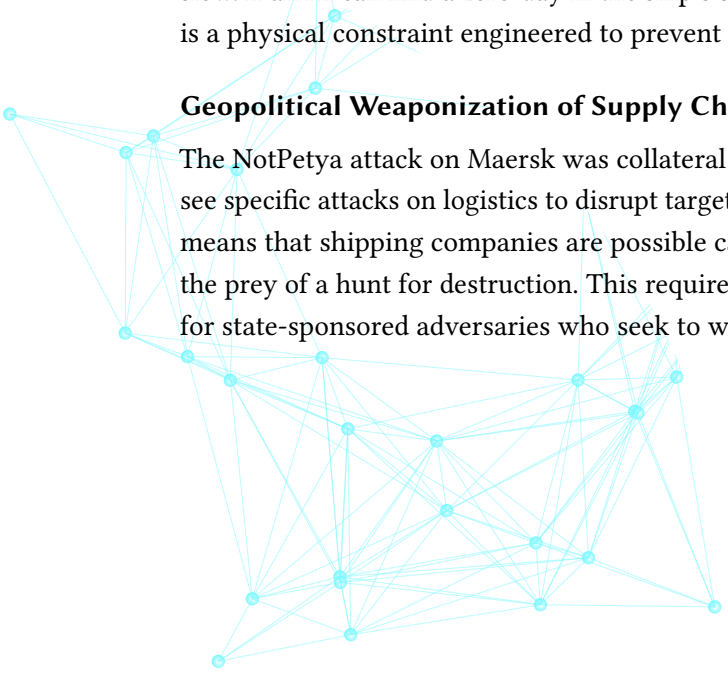
The transition to **Maritime Autonomous Surface Ships (MASS)** presents a profound engineering challenge. In the Maersk incident, the ultimate resource was the human crew, who could manually control the vessel or the cranes even when the IT network failed. In a fully autonomous future, this "analog" backup is removed [4], because organizations aim for an independent system that doesn’t need a crew on board opting for resource efficiency over human work-force. What could go wrong then?

Exacerbating Risk: If a fully autonomous vessel relies solely on digital logic for propulsion and steering, a NotPetya-style wiper could turn a 200,000-tonne cargo ship into a remotely controlled weapon.

The AI Threat: Conversely, attackers are increasingly using Artificial Intelligence to automate vulnerability discovery. This accelerates the "Time to Exploit," rendering traditional patch management cycles too slow. If an AI can find a zero-day in the ship’s satellite link in minutes, the only plausible line of defence is a physical constraint engineered to prevent that zero-day from affecting the engine (CIE).

Geopolitical Weaponization of Supply Chains

The NotPetya attack on Maersk was collateral damage from a national war. Future conflicts will likely see specific attacks on logistics to disrupt targeted state economies. The trend towards “Hybrid Warfare" means that shipping companies are possible candidates to be in the middle of a battle field, becoming the prey of a hunt for destruction. This requires a shift in mindset: resilience engineering must account for state-sponsored adversaries who seek to wreak havoc rather than financial gain.



Conclusions and Outlook

The 2017 NotPetya incident was more than a financial loss for Maersk: it was a systemic warning for the global economy. The paralysis of international trade routes demonstrated that efficiency gains achieved through the convergence of IT and OT have created vulnerable “flat" network architectures susceptible to rapid collapse.

This white paper has argued that the traditional "perimeter defence" model is fundamentally insufficient for critical maritime infrastructure. As long as ships rely on trusted third-party software (like M.E.Doc) and unsegmented networks, they remain vulnerable to supply chain attacks that bypass even DMZ perimeters.

Learning Points:

- **Design solutions to be ready, not to patch:** Assuming that the network will eventually collapse gives a strong incipit to the architecture engineering process, allowing a more resilience focused approach (CIE).
- **Decoupling is essential:** The ability to decouple physical operations (cranes, steering) from digital dependencies is the only reliable way to be prepared against systemic wiper attacks.

The future of maritime logistics depends on acknowledging that the network will be breached. The measure of success is no longer whether they can stop the hacker, but whether the ship can keep sailing, and the port operating, when the screens go black.

Generative AI Usage Disclosure

Perplexity (Pro Version - Gemini 3 Pro Model) by Perplexity AI, Inc. (https://www.perplexity.ai) was used for tone and readability feedback, grammar and spelling checks, polishing the final product, brainstorming and relevant literature discovery (supplemented by Scopus and OneSearch).

References

[1] Cisco Talos Intelligence Group. 2017. *The MeDoc Connection.* https://blog.talosintelligence.com/the-medoc-connection/ Accessed: 2026-02-03.

[2] Cisco Talos Intelligence Group. 2017. *New Ransomware Variant "Nyetya" Compromises Systems Worldwide.* https://blog.talosintelligence.com/worldwide-ransomware-variant/ Accessed: 2026-02-03.

[3] Cybersecurity and Infrastructure Security Agency. 2017. *Petya Ransomware.* https://www.cisa.gov/news-events/alerts/2017/07/01/petya-ransomware Accessed: 2026-02-03.

[4] Sustainability Directory. 2025. *Cybersecurity Threats to Autonomous Maritime Vessels.* https://prism.sustainability-directory.com/scenario/cybersecurity-threats-to-autonomous-maritime-vessels/ Accessed: 2026-02-05.

[5] European Commission. 2023. *The NIS2 Directive: A High Common Level of Cybersecurity in the EU.* https://digital-strategy.ec.europa.eu/en/policies/nis2-directive Accessed: 2026-02-05.

[6] Andy Greenberg. 2017. *What Is the Petya Ransomware Spreading Across Europe? WIRED Explains.* https://www.wired.com/story/petya-malware-ransomware-attack-outbreak-june-2017/ Accessed: 2026-02-03.

[7] Idaho National Laboratory. 2019. *Consequence-driven Cyber-informed Engineering (CCE).* Technical Report. INL, U.S. Department of Energy. https://inl.gov/national-security/cce/ Accessed: 2026-02-03.

[8] Idaho National Laboratory. 2020. *CCE Phase 1: Consequence Prioritization.* Technical Report INL/EXT–20-58089-Rev000. INL, U.S. Department of Energy. https://www.osti.gov/biblio/1617458 Accessed: 2026-02-03.

[9] International Association of Classification Societies. 2022. *Unified Requirements E26 and E27: Cyber Resilience of Ships.* https://www.classnk.or.jp/hp/en/activities/cybersecurity/ur-e26e27.html Accessed: 2026-02-05.

[10] LogRhythm Labs. 2017. *NotPetya Technical Analysis.* Threat Intelligence Report. LogRhythm. https://gallery.logrhythm.com/threat-intelligence-reports/notpetya-technical-analysis-logrhythm-labs-threat-intelligence-report.pdf Accessed: 2026-02-03.

[11] National Institute of Standards and Technology. 2017. CVE-2017-0144: Vulnerability in SMBv1 Server (EternalBlue). NIST National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2017-0144 Accessed: 2026-02-03.

[12] Sean Steinberg, Adam Stepan, and Kyle Neary. 2021. *NotPetya: A Columbia University Case Study.* Case Study SIPA-21-022.1. School of International and Public Affairs (SIPA), Columbia University. https://www.sipa.columbia.edu/sites/default/files/2022-11/NotPetya%20Final.pdf Accessed: 2026-02-02.

[13] U.S. Department of Energy. 2022. *National Cyber-Informed Engineering Strategy.* Technical Report. Office of Cybersecurity, Energy Security, and Emergency Response (CESER). https://inl.gov/content/uploads/2023/07/FINAL-DOE-National-CIE-Strategy-June-2022_0.pdf Accessed: 2026-02-03.